

Data Privacy & GDPR Compliance Policy

Owning area: Legal_Terms

Policy ID: LEG-PRV-001

Version: 4.2

Last reviewed: August 2026

Policy owner: Group Data Protection Officer (DPO)

1. Purpose and Overview

This policy defines how IronStore collects, uses, stores, shares, and protects personal data in accordance with the General Data Protection Regulation (GDPR), applicable national privacy laws, and contractual obligations.

IronStore sells consumer products across Europe, including electronics, home essentials, clothing, outdoor equipment, beauty products, and related categories. The policy applies to customer, employee, supplier, courier, marketplace, and website visitor data processed through IronStore systems or on its behalf.

Compliance is mandatory. Business teams must involve Legal_Terms before launching processing activities that create new privacy risks, introduce new tracking technologies, or materially change how personal data is used.

2. Scope

This policy applies to:

- IronStore GmbH and all European subsidiaries and branches.
- Employees, temporary workers, contractors, and approved service providers.
- Customer-facing websites, mobile applications, marketplaces, customer service channels, and fulfilment operations.
- Personal data in production, test, support, analytics, backup, and paper environments.
- Processing performed by third parties under an IronStore contract.

The policy covers personal data relating to identified or identifiable individuals. Anonymous information, which cannot reasonably be linked to an individual, is outside the GDPR but must still be handled securely.

3. Policy Statement and Procedures

3.1 Core Privacy Principles

IronStore processes personal data according to these principles:

- **Lawfulness, fairness, and transparency:** use a valid legal basis and provide clear notices.
- **Purpose limitation:** use data only for defined, compatible business purposes.

- **Data minimisation:** collect only information necessary for the stated purpose.
- **Accuracy:** enable correction and remove data that is no longer reliable.
- **Storage limitation:** retain data only for approved periods.
- **Integrity and confidentiality:** protect data against unauthorised access, loss, alteration, or disclosure.
- **Accountability:** maintain evidence of decisions, controls, training, and reviews.

No team may use customer data for a new purpose merely because the data is already available in Salesforce, Snowflake, Magento, or another approved system.

3.2 Lawful Basis and Transparency

The responsible business owner must document the lawful basis before processing begins. Approved bases include:

- **Contract:** order fulfilment, payment processing, delivery, returns, and customer account administration.
- **Legal obligation:** tax, accounting, product safety, fraud prevention, and regulatory reporting.
- **Legitimate interests:** service security, limited operational analytics, debt recovery, and carefully assessed business communications.
- **Consent:** optional marketing, non-essential cookies, personalised advertising, and certain profiling activities.
- **Vital interests or public task:** only where specifically validated by Legal_Terms.

Marketing consent must be recorded in the **ConsentHub** service, including timestamp, wording presented, channel, country, and withdrawal status. Pre-ticked boxes, bundled consent, and consent obtained through misleading wording are prohibited.

Every customer-facing collection point must link to the current **Privacy Notice**. Material changes require approval from Legal_Terms and, where appropriate, renewed consent.

3.3 Data Collection and Classification

Teams must classify information in the IronStore Data Register:

- **Public:** information approved for public release.
- **Internal:** routine business information with limited impact if disclosed.
- **Confidential:** personal data, commercial information, and customer records.
- **Restricted:** payment data, identity documents, authentication secrets, health information, or high-risk combinations of data.

Sensitive or special-category data must not be collected unless expressly required, legally justified, and approved by the DPO. Payment card numbers must not be stored in IronStore applications; payments must use the tokenised **Adyen** platform.

Production personal data must not be copied into development or training environments. Where testing requires realistic records, teams must use synthetic data or an approved anonymisation process.

3.4 Access Control and Security

System owners must apply least-privilege access and review permissions at least quarterly. Access to restricted data requires multi-factor authentication through **Microsoft Entra ID** and must be logged.

Minimum controls include:

- Role-based access in **Magento Commerce**, Salesforce Service Cloud, Snowflake, and warehouse systems.
- Encryption in transit using TLS 1.2 or higher and encryption at rest for hosted databases.
- Endpoint protection and managed device controls through Microsoft Intune.
- Central security monitoring in Microsoft Sentinel.
- Immediate access removal when employment or supplier access ends.
- No transmission of customer files through personal email, consumer file-sharing services, or unapproved messaging applications.

Exporting more than 10,000 customer records, or any restricted dataset, requires written approval from the system owner and the DPO or delegated Privacy Counsel.

3.5 Retention and Deletion

The approved retention schedule is maintained in **LEG-PRV-004 Data Retention Standard**. Unless a longer period is required by law, contract, or an active dispute:

- Order, invoice, and tax records: **10 years** after the relevant financial year.
- Customer account data: until account closure, then deleted or anonymised within **90 days**.
- Customer service cases: **3 years** after closure.
- Marketing suppression records: retained only to honour opt-out requests.
- Delivery and returns records: **3 years** after completion.
- Web analytics identifiers: **14 months**, unless a shorter consent setting applies.
- CCTV footage at fulfilment sites: normally **30 days**, subject to incident preservation.

Deletion jobs run monthly through the **Data Lifecycle Manager**. Legal holds, fraud investigations, chargebacks, and regulatory requests suspend deletion for the affected records. Business owners must document the reason and expected end date.

3.6 Individual Rights Requests

Individuals may exercise rights through the privacy form on IronStore.eu, by emailing **privacy@ironstore.eu**, or through Customer Support. Requests must be recorded in **PrivacyDesk** and acknowledged within five business days.

The Privacy Operations team must:

1. Verify identity using proportionate checks; do not request unnecessary identity documents.
2. Search relevant systems, including CRM, order, marketing, support, and consent records.
3. Consult Legal_Terms where exemptions, third-party data, or complex searches apply.

4. Respond without undue delay and normally within one month.
5. Extend the deadline by up to two additional months only where the request is complex; notify the requester within the first month.
6. Record the outcome, search scope, approvals, and response date.

Requests include access, correction, deletion, restriction, portability, objection, and withdrawal of consent. Automated decisions with legal or similarly significant effects require a documented human review route.

3.7 Cookies, Tracking, and Profiling

Non-essential cookies, advertising pixels, session replay, and similar technologies require prior consent in the **CookieHub CMP**. Strictly necessary technologies may operate without consent where legally permitted.

The Web Product team must:

- Maintain an approved tag inventory.
- Block unconsented tags before consent is recorded.
- Re-scan production websites monthly.
- Obtain Privacy Engineering approval before adding a new vendor tag.
- Record vendor, purpose, data categories, retention, and transfer location.

Personalised recommendations may use purchase and browsing data only for documented purposes. High-impact profiling, sensitive inferences, or combined datasets require a DPIA and DPO approval before deployment.

3.8 Suppliers and International Transfers

Procurement must involve Legal_Terms before a supplier receives personal data. Contracts must include appropriate data processing terms, confidentiality, security controls, subprocessor notification, audit rights, deletion or return obligations, and assistance with GDPR rights.

The supplier must be listed in the **Vendor Privacy Register**. Data Processing Agreements are mandatory for processors unless Legal_Terms documents a justified exception.

Transfers outside the European Economic Area require an approved mechanism, such as:

- An adequacy decision.
- EU Standard Contractual Clauses.
- Binding Corporate Rules.
- A documented derogation for an occasional, necessary transfer.

Legal_Terms must complete a Transfer Impact Assessment where required. Teams may not approve a vendor's standard international transfer terms without review.

3.9 Data Protection Impact Assessments

A DPIA is required before processing likely to create a high risk to individuals, including:

- Large-scale profiling or behavioural advertising.
- Systematic monitoring of public areas or workers.
- Processing special-category data at scale.
- Biometric identification or significant automated decision-making.
- Combining datasets from multiple business functions.
- A new technology that materially changes the risk profile.

The project owner completes the **DPIA Template LEG-PRV-006** with Security and Engineering. The DPO approves, rejects, or requires mitigations before go-live. Unresolved high risks must be referred to the relevant supervisory authority where legally required.

3.10 Incidents and Personal Data Breaches

Employees must report suspected loss, unauthorised access, misdirected emails, ransomware, or accidental disclosure immediately through **security@ironstore.eu** and the **ServiceNow Security Incident** form. Reports should be made within one hour where possible.

Security Operations leads containment and evidence preservation. The DPO assesses notification requirements with Legal_Terms:

- Supervisory authority notification is targeted within 72 hours of becoming aware of a reportable breach.
- Affected individuals are notified without undue delay where the risk is high.
- All incidents, including non-reportable events, are recorded in the Breach Register.
- Employees must not contact regulators, customers, or media about an incident unless authorised.

3.11 Training and Monitoring

All personnel complete privacy and information security training during onboarding and annually thereafter. Customer Support, Marketing, Product, Engineering, HR, and fulfilment managers receive role-specific training.

Compliance is monitored through quarterly access reviews, annual supplier assessments, retention-job reports, cookie scans, and internal audits. Repeated non-compliance may result in access restrictions, disciplinary action, contract termination, or escalation to the Executive Risk Committee.

4. Roles and Responsibilities

- **Group DPO:** oversees GDPR compliance, advises leadership, manages high-risk assessments, and acts as supervisory-authority contact.
- **Legal_Terms / Privacy Counsel:** approves notices, contracts, lawful-basis assessments, DPIAs, transfers, and complex rights requests.
- **Business owners:** define purposes, maintain records, approve access, and ensure retention.
- **Engineering and Security:** implement technical safeguards, logging, monitoring, and incident response.
- **Procurement:** ensures privacy review and contractual controls before supplier onboarding.
- **Customer Support:** verifies and routes rights requests without making unauthorised disclosures.

- **All personnel:** follow this policy, complete training, and report suspected incidents promptly.

Contact: privacy@ironstore.eu | Internal channel: **#privacy-help**

5. Related Documents and References

- **LEG-PRV-002:** IronStore Privacy Notice
- **LEG-PRV-003:** Cookie and Online Tracking Standard
- **LEG-PRV-004:** Data Retention Standard
- **LEG-PRV-005:** Data Processing Agreement Template
- **LEG-PRV-006:** Data Protection Impact Assessment Template
- **SEC-STD-001:** Information Security Policy
- **OPS-INC-002:** Security Incident and Breach Response Procedure
- Regulation (EU) 2016/679 (General Data Protection Regulation)
- Applicable national data protection and electronic communications laws

6. Revision History

- **v4.2 — August 2026:** Annual review; updated retention periods, CookieHub controls, and transfer assessment requirements.
- **v4.1 — February 2026:** Added Snowflake export approval threshold and revised rights-request workflow.
- **v4.0 — August 2025:** Consolidated privacy, cookie, supplier, and breach requirements into one policy.